

תמצית + תקציר שיעור 1 – הגנת הפרטיות

1. מטרת הקורס ומה עושים בו

הקורס מובנה כך שהסטודנט ייצא עם יכולת אמיתית לבצע סקר פרטיות ולבנות תוכנית עבודה לפרטיות בארגון.

מה נעשה במהלך הקורס:

1. נלמד את החוק הישראלי ותקנות פרטיות (כולל תיקון 13).
2. נתרגל עם "תני" איך הופכים חוק לפרקטיקה.
3. נתנסה בניתוח Use-Cases אמיתיים של חברות.
4. נקבל שיעורים אורחים בתחום האכיפה GDPR, וארה"ב.
5. נעשה פרויקט גמר:

- בחירת חברה (אמיתית/פיקטיבית)
- מיפוי מידע ודרישות חוק
- איתור פערים
- בניית תוכנית עבודה
- הכנת מצגת הנהלה (10–12 שקפים)

6. נציג את הממצאים – ונעבור "שפשוף" אמיתי של הצגה להנהלה.

2. עקרונות - על של פרטיות

2.1 עיקרון צמידות המטרה (הכי חשוב)

"לא ניתן להשתמש במידע למטרה אחרת מזו שלשמה נאסף".

דוגמה:

מרצה נתן מספר טלפון לצורך תיאום הגעה ← אסור להעביר אותו למשתתפי הכנס ללא הסכמה.

זהו העיקרון שיחזור כל הזמן במבחן.

2.2 הבטחת מידע ≠ פרטיות

- אפשר שהמערכת תהיה מאובטחת מאוד אבל לא פרטית בכלל.
- פרטיות עוסקת ב"איך" משתמשים במידע.
- אבטחת מידע היא תנאי סף אך לא "במקום" פרטיות.

2.3 הסכמה (הבסיס החוקי לעיבוד מידע)

בישראל יש שני בסיסים חוקיים בלבד:

1. הסכמה
2. הסכמה מפורשת בחוק

סוגי הסכמה:

- **מכללא** (מתוך הפלל, לא בפרוש) – הסכמה שלא ניתנת באופן מפורש, אך משתמעת מתוך התנהגות הצדדים או מהנסיבות (ביקור באתר).
- **במפורש** – סימון וי למטרה ספציפית.
- **מדעת** – הכי חשובה; האדם יודע:
 - איזה מידע נאסף
 - למה
 - למי מועבר
 - כמה זמן נשמר
 - מי מנהל המאגר

*רשות הפרטיות דוחפת למצב שבו כמעט כל עיבוד דורש הסכמה מדעת.

3. מבנה משפטי של הגנת הפרטיות בישראל

3.1 היררכיית נורמות

1. חוק יסוד כבוד האדם וחירותו – הזכות לפרטיות (ס' 7)
2. חוק הגנת הפרטיות (1981) – כולל תיקון 13 (2023)
3. תקנות – הבטחת מידע, שעות, הנחיות
4. פסיקה
5. הנחיות / חוות דעת של הרשות (לא מחייבות אך בעלות משקל גדול)

4. הגדרות יסוד (הכי חשוב!)

ההבנה של 4 ההגדרות האלו = 50% מהבנה של הנושא.

4.1 "מאגר מידע"

* משפט חובה לזכור:

מאגר מידע ≠ מערכת מידע

הגדרה:

אוסף מידע אישי שמנוהל באמצעי דיגיטלי, בעל מבנה פנימי כלשהו (רשומות / טבלאות).

שתי החרגות:

1. שימוש אישי (רשימת מוזמנים לחתונה)
2. שם + מען + דרכי קשר עד 100,000 רשומות ו- ללא מידע אישי נוסף

* כתובת מייל נחשבת מידע אישי נוסף.

4.2 "מידע אישי"

כל פרט שמאפשר לזהות אדם באופן ישיר או עקיף.

דוגמאות:

שם, טלפון, אימייל, כתובת IP, קואורדינטות, מזהה פנימי, נתוני שימוש.

* כמעט כל נתון היום יכול לזהות אדם.

4.3 "מידע ברגישות מיוחדת" (חדש בתיקון 13)

רשימה סגורה:

1. מידע רפואי.
2. גנטי.
3. ביומטרי.
4. עבר פלילי.
5. דעות פוליטיות.
6. אמונה דתית.
7. נתוני מיקום ותעבורה של ספק תקשורת.
8. הערכת אישיות על ידי גורם מקצועי.
9. מידע פיננסי.
10. מידע שחלה עליו חובת סודיות מקצועית.

*מידע זה דורש חובות מוגברות ואבטחה מחמירה.

4.4 עיבוד מידע

כל פעולה במידע:

איסוף, ארגון, אחסון, עיון, שינוי, מחיקה, מתן גישה, העברה.

*בפועל: עצם זה שספק ענן רואה את המידע = הוא מחזיק.

5. שחקנים במגרש

5.1 בעל שליטה במאגר (בד"כ: הארגון)

מי שקובע מטרת המאגר:

- מה אוספים?
- למה?
- איך?
- באילו מערכות?

5.2 מחזיק במאגר

מי שמבצע עיבוד עבור בעל השליטה: ספקים, מערכות ענן, תמיכה טכנית.

5.3 מנהל המאגר

האדם שממונה מטעם בעל השליטה לתפקיד.
בגופים ציבוריים – המנכ"ל (אלא אם מונה אחר).

6. מידע פומבי ≠ מותר לשימוש

העיקרון:
"מה שקורה בווגאס נשאר בווגאס"

גם אם אדם פרסם משהו בפייסבוק עדיין אסור לחברה להשתמש בו (כי זאת מטרה אחרת).

7. מיפוי מאגרי מידע – השלב הראשון בכל פרויקט

להבין את הנושא השיעור = להבין את סדר הפעולות:

1. מיפוי סוגי המידע.
2. הבנת מטרות איסוף.
3. איתור מערכות.
4. זיהוי ספקים.
5. מציאת פערי אבטחה/פרטיות.
6. בניית תוכנית עבודה לסגירת פערים.

8. מה לזכור?

8.1 מה נדרש ממני?:

- ✓ דגש על צמידות מטרה.
- ✓ שליטה בהגדרות.
- ✓ יכולת ליישם מיפוי מאגר + פערים.
- ✓ הבנה של הסכמה מדעת.
- ✓ הבחנה בין פרקטיקה לחוק.
- ✓ הכרות עם מידע רגיש.
- ✓ הבחנה בין בעל שליטה – מחזיק – מנהל מאגר.

8.2 נוסחאות זיכרון (עוגני זיכרון)

- א. מאגר $\neq$ מערכת
מאגר = מה בסל
מערכת = איפה הסל יושב
- ב. מידע אישי = מה מזהה אדם
יש זיהוי? זה אישי.
- ג. צמידות מטרה = אין שינוי ייעוד ללא הסכמה
- ד. רגישות מיוחדת = רשימה סגורה
רפואי, גנטי, ביומטרי, פלילי, פוליטי, דתי, פיננסי, מקצועי, מיקום, סודיות.
- ה. עיבוד = כל נגיעה במידע

9. תמצית השיעור (אולטרה-קצרה)

- המטרה: שימוש חוקי, מצומצם ומידתי במידע.
- הסכמה מדעת = הבסיס לכל.
- צמידות מטרה = אסור לשנות ייעוד.
- מידע אישי = כל מה שמזהה אדם.
- מידע רגיש = צריך אבטחה מוגברת.
- מאגר $\neq$ מערכת.
- בעל שליטה קובע מטרות; מחזיק מבצע; מנהל ממונה.

- מידע פומבי עדיין מוגן.
- מיפוי מאגרים הוא בסיס לכל עבודה.